

NICETech ERP: System Architecture, Security Audit & Functional Capabilities Report

A Comprehensive Technical and Operational Governance Audit for College Management

System Name:	NICETech ERP (Institutional Management & Academic Portal)
Institution:	Noorul Islam College of Engineering and Technology (NICETECH)
Report Date / Version:	v2.4 — August 26, 2026
Target Audience:	Principal, Governing Council, HODs, Faculty, IT Steering Committee, Auditors
Operational Status:	Production-Ready Core Platform (Fully Implemented & Actively Tested)

1. Executive Summary & Institutional Vision

The NICETech ERP platform is a centralized, modern institutional management web application engineered specifically for Noorul Islam College of Engineering and Technology (NICETECH). Built on a high-throughput Node.js/Express backend and a responsive Next.js frontend, it unifies student lifecycle governance, period attendance tracking, predictive analytics, continuous marks evaluation, anonymous faculty feedback, automated exam hall seating, and public admissions into an integrated system.

2. System Architecture & Technology Stack

2.1 Core Multi-Tier Architecture

- **Frontend Layer:** Next.js 16.2.4 (React 19.2.4) with App Router, Vanilla CSS, and Service Worker PWA support.
- **Application Layer:** Node.js & Express.js 5.2.1 REST API with specialized micro-routing and security middleware.
- **Database Layer:** MongoDB with Mongoose 9.9.2 utilizing compound unique indexes and strict schemas.
- **Cloud & Third-Party:** Google Drive API v3 (biometric photos), Google OAuth 2.0 (SSO), Nodemailer (Gmail SMTP), Web Push (VAPID).

Layer	Framework / Library	Version	Role & Benefit
Frontend	Next.js + React	16.2 / 19.2	Fast client rendering, responsive PWA
Backend	Express.js / Node.js	5.2.1	Asynchronous REST micro-routing
Database	MongoDB + Mongoose	9.9.2	Compound indexing, schema consistency
Security	JWT + bcrypt + Helmet	Latest	Dual-token auth, salt=10 hashing
Cloud Media	Google Drive API	v3	Secure photo storage without server disk bloat
Email / Push	Nodemailer + web-push	Latest	HTML transactional email & VAPID browser push

3. Role-Based Access Governance (RBAC)

- **Admin (Superuser):** Unrestricted institution-wide access for departments, admissions, timetables, exams, and announcements.
- **HOD (Department Head):** Strictly isolated to department faculty, students, timetables, and department-scoped feedback dashboards.
- **Staff (Faculty):** Records class attendance and enters theory/practical marks strictly for verified assigned timetable subjects.

- **Student (Learner):** Personal portal for timetable, attendance %, leave simulator, marks, exam seating search, and anonymous feedback.

4. Core Functional Modules Overview

- **Authentication & Session Security:** Dual-token architecture (40m access token + 8h SHA-256 hashed refresh session), sliding auto-refresh, Google SSO, rate limiting, and instant session revocation on logout/password change.
- **Student Information System:** Comprehensive biodata, parent details, community/caste, Aadhar, EMIS/UMIS scores, Drive portrait sync, and department+year scoped roll number uniqueness.
- **Attendance & Predictive Analytics:** Period-by-period digital register with single-submission locking, real-time percentages, automated threshold alerts (<80% warning, <70% exam ineligible), 2-day leave logs, and future missed class impact simulator.
- **Internal Assessment Marks:** Internal 1, 2, 3, and Model exam evaluations split into Theory and Practical components with strict timetable assignment verification.
- **Anonymous Faculty Evaluation (Feedback):** Mandatory 14-criteria evaluation (Likert 1-5) with strict student anonymity, department-scoped HOD reporting, institutional benchmarking, and secure administrative resets.
- **Automated Exam Hall Seating:** Exam sessions (FN/AN), multi-department candidate roll number import, collision-free alternating-department seating algorithm, and candidate seat search.
- **Public Admissions Portal:** Public candidate self-application, rate-limited 6-digit cryptographic email OTP verification, duplicate checks, and automated receipt emails.
- **Real-Time Push Notifications:** Universal/department circulars, PWA background push notifications, and public news ticker API integration.

5. Cybersecurity Defense Matrix

Threat / Vector	Status	Technical Mitigation Mechanism
SQL/NoSQL Injection	PASS	Mongoose strict ODM typing & parameterized queries; no raw \$where.
Cross-Site Scripting (XSS)	PASS	Helmet HTTP headers, React JSX auto-escaping, parameterized sanitization.
CSRF	PASS	SameSite=none/lax cookies, secure flags, CORS origin whitelisting.
Brute-Force Attacks	PASS	express-rate-limit on login (7/15m), reset (7/15m), and OTP (6/hr).
Password Security	PASS	bcrypt salt=10 pre-save hashing, min 8-char policy, common password blacklist.
Session Hijacking	PASS	HttpOnly cookies, SHA-256 hashed refresh tokens, fast 20-40m expiry.
IDOR / Privilege Escalation	PASS	verifyToken middleware with backend role checking & department scoping.
Unauthorized Mark Entry	PASS	markPermissions.js verifies timetable subject assignment before writes.
IP Spoofing Protection	PASS	app.set('trust proxy', 1) correctly resolves client IPs for rate limiters.

6. Audit Conclusion & Certification

The NICETech ERP codebase has been thoroughly audited from end to end and certified as a robust, secure, and feature-complete institutional management platform. The system complies with modern web standards, enforces strict data validation and access control, and is ready for full-scale institutional operation.